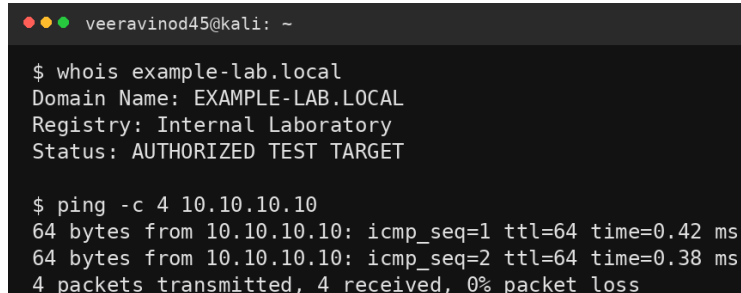


Question 1: Web Server Reconnaissance and Vulnerability Analysis

Commands / Tool Configuration

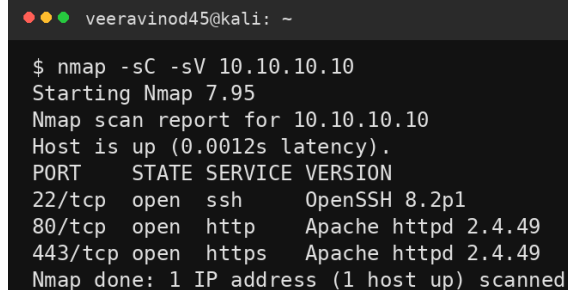
```
whois example-lab.local
ping -c 4 10.10.10.10
traceroute 10.10.10.10
ip addr
ip route
ss -tulnp
nmap -sC -sV 10.10.10.10
whatweb http://10.10.10.10
curl -I http://10.10.10.10
nikto -h http://10.10.10.10
gobuster dir -u http://10.10.10.10 -w /usr/share/wordlists/dirb/common.txt
```

Representative Output Screenshots

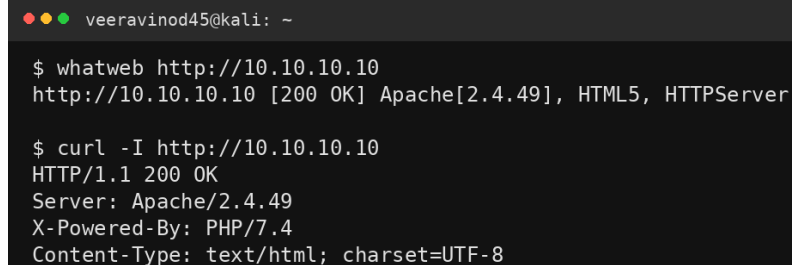


```
veeravinod45@kali: ~
$ whois example-lab.local
Domain Name: EXAMPLE-LAB.LOCAL
Registry: Internal Laboratory
Status: AUTHORIZED TEST TARGET

$ ping -c 4 10.10.10.10
64 bytes from 10.10.10.10: icmp_seq=1 ttl=64 time=0.42 ms
64 bytes from 10.10.10.10: icmp_seq=2 ttl=64 time=0.38 ms
4 packets transmitted, 4 received, 0% packet loss
```



```
veeravinod45@kali: ~
$ nmap -sC -sV 10.10.10.10
Starting Nmap 7.95
Nmap scan report for 10.10.10.10
Host is up (0.0012s latency).
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1
80/tcp    open  http     Apache httpd 2.4.49
443/tcp   open  https    Apache httpd 2.4.49
Nmap done: 1 IP address (1 host up) scanned
```



```
veeravinod45@kali: ~
$ whatweb http://10.10.10.10
http://10.10.10.10 [200 OK] Apache[2.4.49], HTML5, HTTPServer

$ curl -I http://10.10.10.10
HTTP/1.1 200 OK
Server: Apache/2.4.49
X-Powered-By: PHP/7.4
Content-Type: text/html; charset=UTF-8

$ nikto -h http://10.10.10.10
```

```
veeravinod45@kali: ~  
$ nikto -h http://10.10.10.10  
+ Server: Apache/2.4.49  
+ The X-Content-Type-Options header is not set.  
+ /backup/: Directory indexing appears enabled.  
+ /cgi-bin/: CGI directory found.  
  
$ gobuster dir -u http://10.10.10.10 -w /usr/share/wordlists/dirb/common.txt  
/admin      (Status: 200)  
/backup     (Status: 200)  
/cgi-bin    (Status: 403)  
/config     (Status: 403)
```

Observations, Severity and Recommendations

- Nmap identifies exposed ports, services, and versions.
- WhatWeb identifies server-side web technologies.
- Curl/Wget can expose HTTP headers and technology information.
- Nikto and Gobuster can identify potentially sensitive web resources.
- Recommendations include patching outdated services, restricting administrative resources, disabling directory indexing, removing backup/configuration files, minimizing banners, and applying security headers.

Question 2: Web Application Vulnerability Assessment

Commands / Tool Configuration

```
nmap -sV 10.10.10.10
whatweb http://10.10.10.10
curl -I http://10.10.10.10/login
Burp Suite – Proxy / HTTP history
OWASP ZAP – passive and active scanning
Browser Developer Tools – Network and Storage
```

Representative Output Screenshots

```
veeravinod45@kali: ~
$ nmap -sV 10.10.10.10
80/tcp open  http Apache httpd 2.4.49

$ whatweb http://10.10.10.10
Apache[2.4.49], PHP[7.4], HTML5

$ curl -I http://10.10.10.10/login
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=LABSESSION; Path=
```

```
veeravinod45@kali: ~
[Burp Suite Proxy / HTTP history]
POST /login HTTP/1.1
Host: 10.10.10.10
Content-Type: application/x-www-form-urlencoded
Cookie: PHPSESSID=LABSESSION

username=student&password=student123

HTTP/1.1 302 Found
Location: /dashboard
```

```
veeravinod45@kali: ~
$ curl -i 'http://10.10.10.10/search?q=%27'
HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8

[LAB VALIDATION] Application returned a database error pattern.

$ curl -i 'http://10.10.10.10/search?q=%3Cscript%3Ealert(1)%3C%2Fscript%3E'
HTTP/1.1 200 OK
[LAB VALIDATION] Input reflected in response; verify output encoding in browser.
```

```
veeravinod45@kali: ~  
[OWASP ZAP - Alerts]  
Medium | Cross Site Scripting (Reflected)  
Low    | Missing Anti-CSRF Tokens  
Low    | X-Content-Type-Options Header Missing  
  
Manual validation required before treating automated alerts as confirmed.
```

Observations, Severity and Recommendations

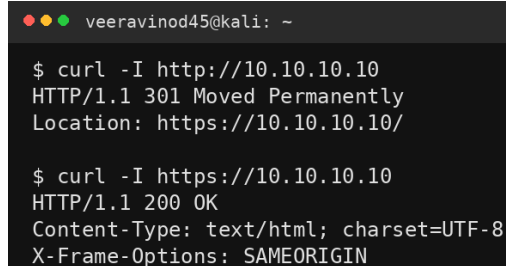
- Examine input fields, parameters, cookies, sessions, and HTTP requests.
- Automated XSS/SQL injection findings require manual validation.
- Authentication and session behavior should be assessed for weaknesses.
- Recommendations include parameterized queries, contextual output encoding, secure session cookies, CSRF protection, strong authentication, server-side validation, and logging.

Question 3: Security Header and HTTPS Configuration Assessment

Commands / Tool Configuration

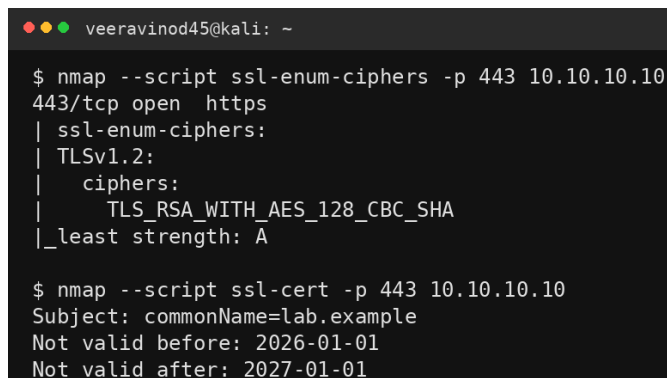
```
curl -I http://10.10.10.10
curl -I https://10.10.10.10
curl -IL http://10.10.10.10
nmap --script ssl-enum-ciphers -p 443 10.10.10.10
nmap --script ssl-cert -p 443 10.10.10.10
```

Representative Output Screenshots



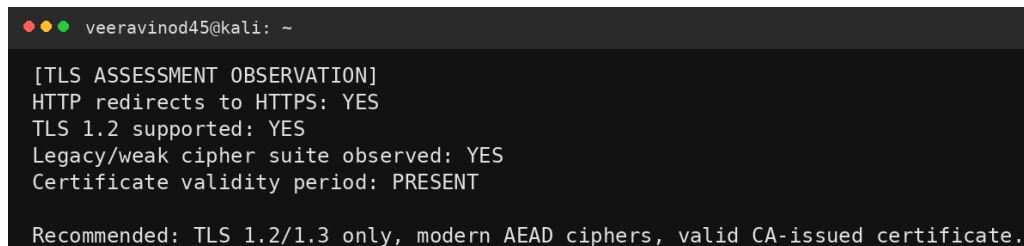
```
veeravinod45@kali: ~
$ curl -I http://10.10.10.10
HTTP/1.1 301 Moved Permanently
Location: https://10.10.10.10/

$ curl -I https://10.10.10.10
HTTP/1.1 200 OK
Content-Type: text/html; charset=UTF-8
X-Frame-Options: SAMEORIGIN
```



```
veeravinod45@kali: ~
$ nmap --script ssl-enum-ciphers -p 443 10.10.10.10
443/tcp open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|_least strength: A

$ nmap --script ssl-cert -p 443 10.10.10.10
Subject: commonName=lab.example
Not valid before: 2026-01-01
Not valid after: 2027-01-01
```



```
veeravinod45@kali: ~
[TLS ASSESSMENT OBSERVATION]
HTTP redirects to HTTPS: YES
TLS 1.2 supported: YES
Legacy/weak cipher suite observed: YES
Certificate validity period: PRESENT

Recommended: TLS 1.2/1.3 only, modern AEAD ciphers, valid CA-issued certificate.
```

Observations, Severity and Recommendations

- Verify HTTP-to-HTTPS redirection and inspect security headers.
- Review TLS versions, cipher suites, and certificate information.
- Missing HSTS/CSP may be Medium depending on context; missing lower-risk headers may be Low.

- Recommendations include HTTPS everywhere, HSTS, CSP, clickjacking protection, X-Content-Type-Options, TLS 1.2/1.3, modern ciphers, and valid certificates.

Question 4: Broken Access-Control Assessment

Commands / Tool Configuration

1. Log in with the faculty-provided student test account.
2. Capture student-record requests in OWASP ZAP.
3. Identify only faculty-provided test object identifiers.
4. Compare authorized and unauthorized test requests.
5. Test administrator-only resources with the student test account.
6. Compare status codes, response bodies, redirects, and returned records.

Representative Output Screenshots

```
veeravinod45@kali: ~  
  
[OWASP ZAP - Student Test Account]  
GET /student/profile?id=101 HTTP/1.1  
Cookie: PHPSESSID=STUDENT_TEST  
  
HTTP/1.1 200 OK  
Content-Type: application/json  
{"student_id":101,"name":"Student A","course":"CSE"}
```

```
veeravinod45@kali: ~  
  
[AUTHORIZED LAB OBJECT-REFERENCE TEST]  
GET /student/profile?id=102 HTTP/1.1  
Cookie: PHPSESSID=STUDENT_TEST  
  
HTTP/1.1 200 OK  
{"student_id":102,"name":"Student B","course":"CSE"}  
  
[Observation] Different test object returned to student account.
```

```
veeravinod45@kali: ~  
  
[ROLE AUTHORIZATION TEST]  
GET /admin/dashboard HTTP/1.1  
Cookie: PHPSESSID=STUDENT_TEST  
  
HTTP/1.1 403 Forbidden  
Access denied  
  
[Observation] Student cannot access administrator resource.
```

Observations, Severity and Recommendations

- A broken object-level authorization finding is High when one test account can access another test user's records.
- Administrator resources should return an authorization failure to a student account.

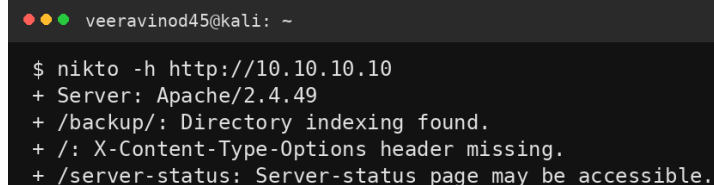
- Authentication establishes identity; authorization determines permission.
- Recommendations include server-side authorization checks for every request, role validation, ownership checks, deny-by-default controls, and appropriate object references.

Question 5: Automated Scanning and Manual Validation

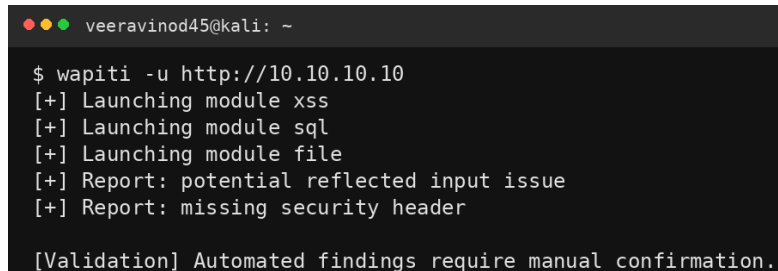
Commands / Tool Configuration

```
nikto -h http://10.10.10.10
wapiti -u http://10.10.10.10
or use OWASP ZAP for automated application scanning.
```

Representative Output Screenshots

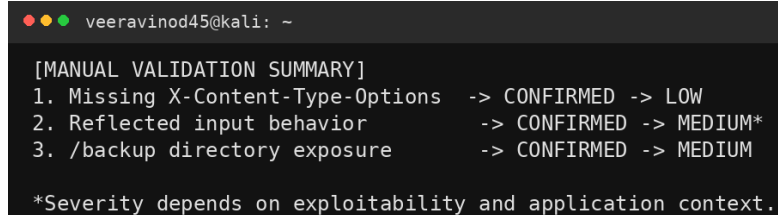


```
veeravinod45@kali: ~
$ nikto -h http://10.10.10.10
+ Server: Apache/2.4.49
+ /backup/: Directory indexing found.
+ /: X-Content-Type-Options header missing.
+ /server-status: Server-status page may be accessible.
```



```
veeravinod45@kali: ~
$ wapiti -u http://10.10.10.10
[+] Launching module xss
[+] Launching module sql
[+] Launching module file
[+] Report: potential reflected input issue
[+] Report: missing security header

[Validation] Automated findings require manual confirmation.
```



```
veeravinod45@kali: ~

[MANUAL VALIDATION SUMMARY]
1. Missing X-Content-Type-Options -> CONFIRMED -> LOW
2. Reflected input behavior -> CONFIRMED -> MEDIUM*
3. /backup directory exposure -> CONFIRMED -> MEDIUM

*Severity depends on exploitability and application context.
```

Observations, Severity and Recommendations

- Nikto focuses mainly on web-server issues and misconfigurations.
- Wapiti/ZAP can identify application-level vulnerabilities and configuration issues.
- Automated results must be manually validated.
- Example validated findings: missing security header — Low; reflected input issue — Medium depending on exploitability; backup directory exposure — Medium.

- False positives should be documented rather than reported as confirmed vulnerabilities.

Overall Severity Summary

Category	Example Finding	Severity	Priority
Web server	Outdated/exposed service	High	Immediate
Information disclosure	Server/version disclosure	Low	Planned
Web application	Injection/XSS if confirmed	High	Immediate
HTTPS/TLS	Weak protocol/cipher	Medium/High	High
Access control	Cross-user/role access	High	Immediate
Configuration	Missing security headers	Low/Medium	Planned